

Manual 12 - Implementação Controlada de Privacidade da Califórnia CCPA / CPRA

CANDIDATO CONTROLADO PARA QA DE PUBLICACAO

Revisão da fonte controlada: 93d5831ff3bd2349eb4973e3a77a8bd3d301c1d4 | Idioma: pt-BR | limites jurídicos de privacidade da Califórnia e datas de conformidade escalonadas mantidos.

Limite jurídico e de asseguração: Este manual operacionaliza práticas de privacidade da Califórnia, mas não fornece aconselhamento jurídico específico para uma organização, não determina aplicabilidade ou isenções, não estabelece suficiência de avaliações de risco, não decide escopo de auditorias de cibersegurança, não determina cobertura ADMT, não estabelece responsabilidade nem garante conformidade com CCPA/CPRA. Obrigações vigentes e escalonadas devem ser aplicadas conforme suas datas de vigência e com julgamento humano jurídico/de privacidade competente.

Caminhos de implementação

Manual 12 — Caminhos de implementação CCPA / CPRA

Rascunho controlado assistido por máquina (pt-BR). A edição em inglês continua sendo a fonte controlada. Esta localização não constitui aprovação jurídica, semântica ou terminológica humana e permanece sujeita a revisão competente antes da publicação.

Estes caminhos dimensionam a profundidade da implementação sem alterar as obrigações jurídicas subjacentes. A aplicabilidade e a interpretação jurídica permanecem específicas de cada organização e exigem julgamento humano competente.

Caminho A — Essencial

Projetado para organizações menores ou menos complexas cujas obrigações de privacidade da Califórnia possam ser operadas em um ambiente de dados comparativamente delimitado.

Pacote operacional mínimo:

- análise de aplicabilidade e limites;
- inventário de papéis para relações de empresa, prestador de serviços, contratado e terceiros;
- inventário de informações pessoais e informações pessoais sensíveis;
- controles de aviso na coleta e política de privacidade;
- entrada, verificação, resposta, prazos e evidências de direitos dos consumidores;
- tratamento de venda/compartilhamento e sinais de preferência de opt-out;
- regras de retenção/eliminação;
- controles contratuais para prestadores de serviços/contratados;
- triagem de avaliação de riscos;
- linha de base de segurança razoável;
- registro de evidências e revisão periódica de gestão.

Caminho B — Estruturado

Projetado para organizações com múltiplas unidades de negócio, sites/apps, ecossistemas de publicidade, fornecedores, produtos de dados ou maior volume de solicitações de consumidores.

Adicione:

- inventário corporativo de fluxos de dados e finalidades;
- testes automatizados de sinais de preferência de opt-out;
- controles de uso/divulgação de informações pessoais sensíveis;
- fluxo de opt-in para menores quando aplicável;
- governança de incentivos financeiros;
- due diligence formal de prestadores de serviços/contratados;
- metodologia documentada de avaliação de riscos e comitê de revisão;

- planejamento de prontidão para auditoria de cibersegurança;
- inventário de ADMT e triagem de aplicabilidade;
- métricas de qualidade de solicitações e revisão de exceções;
- validação de retenção/eliminação de dados;
- integração de engenharia de privacidade à gestão de mudanças;
- pacote de evidências para resposta regulatória.

Caminho C — Aprimorado

Projetado para organizações grandes, intensivas em dados, com forte atividade publicitária, habilitadas por IA, multinacionais ou altamente reguladas.

Adicione:

- framework corporativo de controles de privacidade da Califórnia;
- descoberta automatizada de dados com validação humana;
- monitoramento contínuo de sinais de preferência;
- governança avançada de publicidade, medição e resolução de identidade;
- controles centralizados de informações pessoais sensíveis;
- governança formal do portfólio de avaliações de risco;
- desafio independente para avaliações de risco materiais;
- arquitetura de evidências para auditoria de cibersegurança e prontidão para prazos escalonados;
- governança de decisões significativas com ADMT, avisos prévios ao uso, operações de acesso/opt-out e prontidão para 2027;
- triagem de aplicabilidade de data brokers/DROP quando relevante;
- monitoramento contínuo de terceiros e fluxos de dados;
- métricas executivas de privacidade e acompanhamento de ações corretivas;
- crosswalks com RGPD, NIST Privacy Framework, ISO/IEC 27701, ISO/IEC 27001 e requisitos setoriais quando útil.

Ciclo de privacidade da Califórnia com sete pontos de controle

Gráfico de memória do Manual 12 1

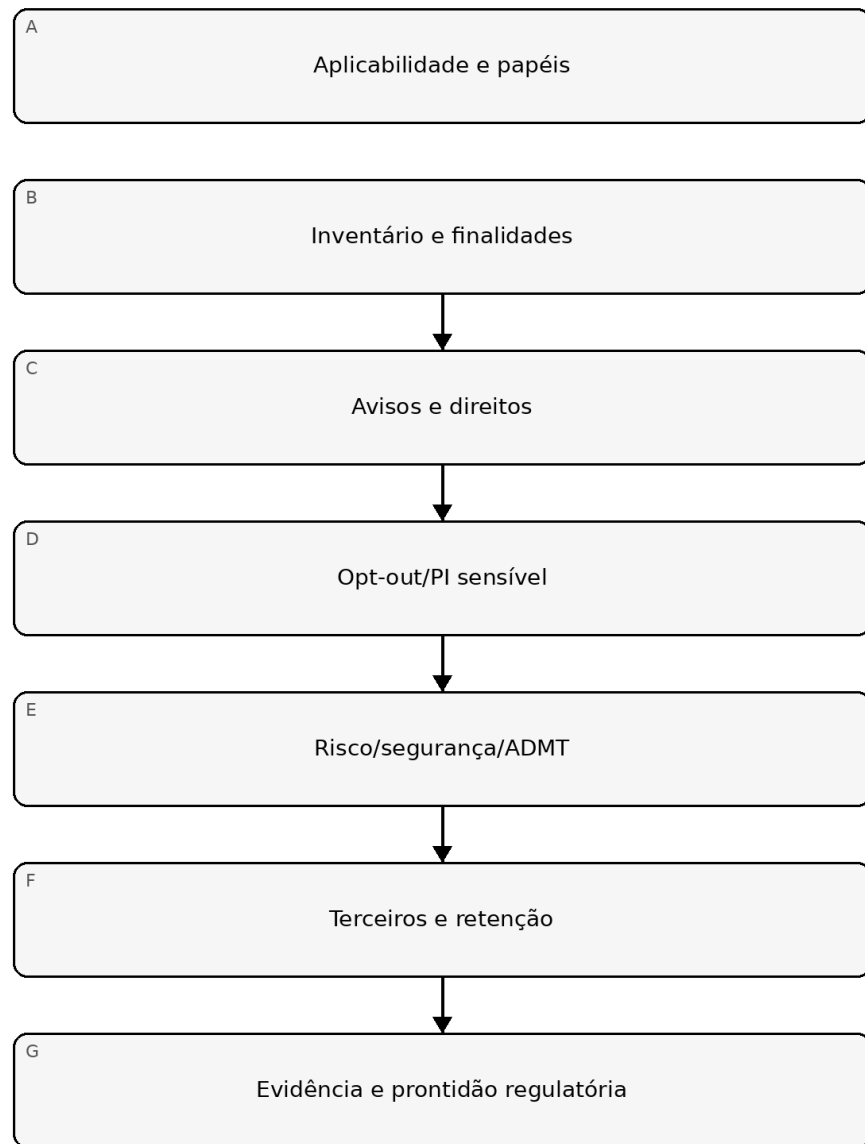


Figura 1. Gráfico de memória de implementação de privacidade da Califórnia

Explicação acessível: O ciclo de privacidade da Califórnia começa com análise de aplicabilidade e papéis, mapeia dados e finalidades, operacionaliza avisos e direitos, trata opt-out e informações pessoais sensíveis, avalia obrigações de risco/segurança/ADMT, governa terceiros e retenção e mantém evidências para revisão e prontidão regulatória.

Roteamento de direitos dos consumidores

Gráfico de memória do Manual 12 2

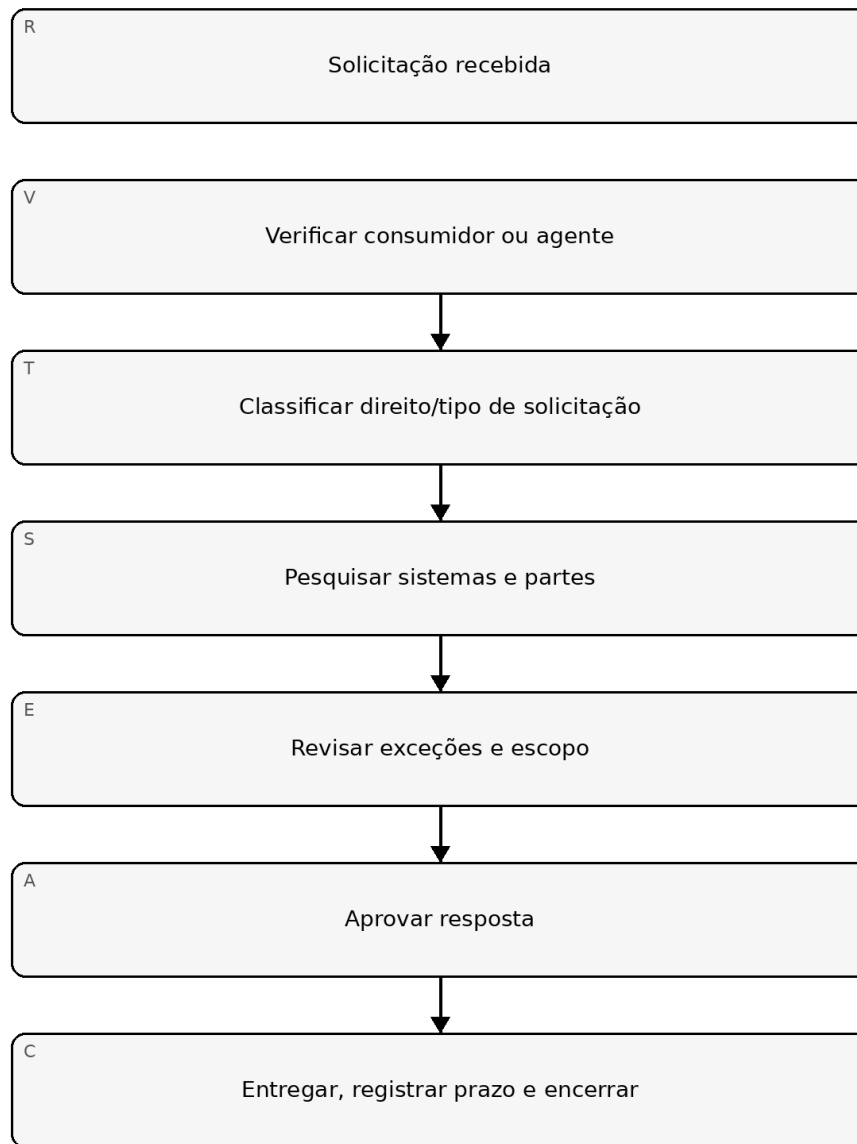


Figura 2. Gráfico de memória de implementação de privacidade da Califórnia

Explicação acessível: Uma solicitação deve ser validada, classificada, pesquisada nos sistemas relevantes e partes downstream, revisada quanto a exceções ou limites de escopo aplicáveis, aprovada por pessoal responsável, entregue dentro dos prazos aplicáveis e encerrada com evidência.

Cronograma regulatório escalonado 2026–2028

Gráfico de memória do Manual 12 3

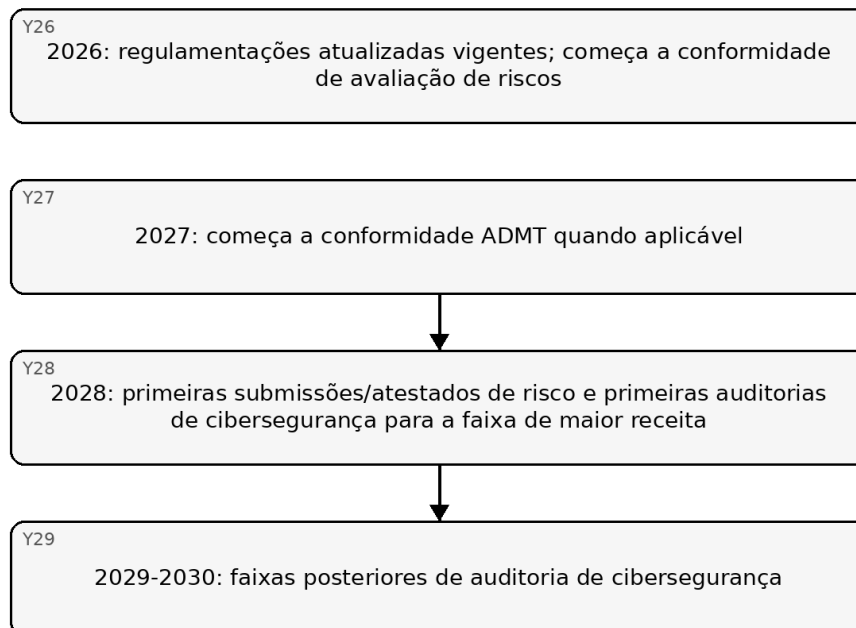


Figura 3. Gráfico de memória de implementação de privacidade da Califórnia

Explicação acessível: As regulamentações atualizadas da CPPA estão em vigor em 2026, mas algumas datas de conformidade são escalonadas. As obrigações de avaliação de riscos começam em 2026; os requisitos de ADMT começam em 2027 quando aplicáveis; as submissões/atestados de avaliação de riscos e as primeiras auditorias de cibersegurança começam em 2028, seguidas por faixas posteriores. A aplicabilidade e as datas exatas devem ser verificadas novamente no candidato final.

Limite fail-closed

A automação pode validar registros obrigatórios, campos de prazo, completude dos fluxos de solicitações, testes de sinais de preferência, links de evidência e rótulos de estado das fontes. Ela não pode emitir conclusões jurídicas finais específicas da organização sobre aplicabilidade, isenções, classificação ADMT, suficiência de avaliação de riscos, escopo de auditoria ou conformidade. A revisão humana competente de privacidade/jurídica permanece obrigatória. A autorização final de liberação do proprietário aplica-se conforme o procedimento permanente do repositório quando todos os pontos de controle substantivos anteriores estiverem verdes.

Manual controlado de 32 capítulos

Capítulo 01 — Finalidade e responsabilidade da privacidade da Califórnia

Estabeleça um modelo operacional controlado que conecte os requisitos de privacidade da Califórnia a responsáveis definidos, inventários de dados, sistemas, sites/apps, tecnologias de publicidade, fornecedores, contratos, operação de direitos dos consumidores, avaliações de risco, segurança, ADMT, retenção, evidência e revisão de gestão.

As conclusões de aplicabilidade devem ser documentadas com fatos, limites, isenções consideradas, revisor, data, premissas e questões não resolvidas.

Capítulo 02 — Aplicabilidade, limites e isenções

Avalie se uma entidade atende à definição legal vigente de empresa coberta e se determinado tratamento ou dado está sujeito a uma isenção ou regra especial. Considere receita, volume de dados, critérios de venda/compartilhamento, relações com entidades sob controle comum, escopo de consumidores da Califórnia e o modelo real de tratamento.

Não infira aplicabilidade apenas pelo porte ou localização da empresa. Reavalie após fusões, mudanças de modelo de negócio, novos usos de dados, mudanças de publicidade ou alterações de limites.

Capítulo 03 — Papéis de empresa, prestador de serviços, contratado e terceiros

Classifique as partes com base no uso real dos dados, restrições contratuais, finalidades, instruções, divulgações downstream e direitos independentes, e não apenas em rótulos.

Mantenha um registro de papéis conectando cada relação a categorias de dados, finalidades, contratos, status de venda/compartilhamento, restrições de prestador de serviços/contratado, subprocessadores ou partes downstream e gatilhos de revisão.

Capítulo 04 — Informações pessoais e contexto de domicílio/dispositivo

Inventarie informações que identifiquem, se relacionem com, descrevam, sejam razoavelmente capazes de ser associadas a ou possam ser razoavelmente vinculadas a um consumidor ou domicílio quando aplicável. Inclua identificadores on-line, dados de dispositivos, comportamento de navegação, geolocalização, informações comerciais, informações relacionadas ao emprego quando cobertas, inferências e registros vinculados.

Registre exclusões ou tratamento de dados desidentificados/agregados com evidência de suporte e restrições de reidentificação quando relevante.

Capítulo 05 — Informações pessoais sensíveis

Identifique informações pessoais sensíveis e determine quais restrições de uso/divulgação, avisos, direitos, controles de segurança e limitações de finalidade se aplicam. Mapeie PI sensível para sistemas, finalidades, destinatários, acesso, retenção e partes downstream.

Tratamento de PI sensível de alto risco deve alimentar governança de avaliação de riscos, segurança, fornecedores, ADMT e incidentes.

Capítulo 06 — Limitação de finalidade e minimização de dados

Defina finalidades específicas para coleta, uso, retenção e compartilhamento. Colete e use dados proporcionalmente às finalidades divulgadas e compatíveis e realize análise de mudança antes de ampliar materialmente o uso.

As decisões de minimização devem estar refletidas em coleta no nível de campos, configuração de SDK/tags, analytics, publicidade, retenção, acesso, exportações, conjuntos de dados de treinamento e instruções a fornecedores quando aplicável.

Capítulo 07 — Governança de privacidade e direitos de decisão

Defina responsabilidades entre privacidade, jurídico, segurança, produto, engenharia, marketing, publicidade, dados, compras, RH, suporte ao cliente, resposta a incidentes, auditoria e liderança executiva.

Estabeleça escalonamento para incerteza de aplicabilidade, conflitos de direitos, questões de venda/compartilhamento, PI sensível, menores, incentivos financeiros, avaliações de risco, auditorias de cibersegurança, ADMT, data brokers e assuntos regulatórios.

Capítulo 08 — Gate fail-closed de fundamentos

Não prossiga como se o programa de privacidade da Califórnia estivesse corretamente delimitado quando a aplicabilidade não estiver resolvida, fluxos materiais de dados forem desconhecidos, as partes estiverem mal classificadas, PI sensível não tiver sido identificada ou faltarem responsáveis de negócio e revisores jurídico/de privacidade.

A automação pode apoiar cálculos de limites e descoberta de dados, mas não pode tomar determinações finais de aplicabilidade, isenção ou papel sem revisão humana competente.

Capítulo 09 — Aviso na coleta

Forneça as informações exigidas no momento da coleta ou antes, em formato apropriado à interação. Conecte os avisos às categorias realmente coletadas, finalidades, PI sensível, retenção, venda/compartilhamento e direitos relevantes.

O design do aviso deve considerar sites, apps móveis, coleta off-line, dispositivos conectados, formulários, call centers, empregados/candidatos quando cobertos e outros canais de coleta.

Capítulo 10 — Política de privacidade e governança de divulgações

Mantenha uma política de privacidade que descreva com precisão as práticas atuais e os direitos aplicáveis dos consumidores. Estabeleça responsáveis, versionamento, revisão jurídica, acessibilidade, gatilhos de atualização, evidência e sincronização com inventários de dados e relações downstream.

Mudanças materiais em finalidades, venda/compartilhamento, PI sensível, ADMT, fornecedores ou operação de direitos devem acionar revisão de impacto sobre a política.

Capítulo 11 — Entrada e verificação de solicitações de consumidores

Forneça os métodos exigidos para que consumidores enviem solicitações aplicáveis e implemente verificação de identidade/autoridade proporcional à solicitação e aos dados envolvidos.

Mantenha controles para agentes autorizados, solicitações de domicílio quando aplicável, menores, contextos com e sem conta, solicitações suspeitas, falhas de verificação e entrega segura de respostas.

Capítulo 12 — Direitos de conhecer/acessar e portabilidade de dados

Implemente busca, agregação de dados, análise de categorias/informações específicas, identificação de fonte/finalidade/destinatário, revisão de exceções, formatação, segurança, aprovação, prazos e entrega para solicitações aplicáveis de acesso/conhecimento.

A evidência deve mostrar quais sistemas e partes downstream foram pesquisados, limitações aplicadas, decisões tomadas e quando a resposta foi entregue.

Capítulo 13 — Eliminação e correção

Encaminhe solicitações de eliminação e correção pelos sistemas relevantes e prestadores de serviços/contratados, aplique exceções documentadas quando apropriado, valide a conclusão downstream e preserve evidências sem reter desnecessariamente os dados que devem ser eliminados.

Fluxos de correção devem tratar decisões de fonte oficial, registros conflitantes, dados derivados e repropragação para sistemas dependentes quando exigido.

Capítulo 14 — Venda, compartilhamento e sinais de preferência de opt-out

Determine se divulgações constituem venda ou compartilhamento conforme as definições aplicáveis da Califórnia e opere mecanismos de opt-out de acordo. Implemente sinais reconhecidos de preferência de opt-out de forma consistente com as regulamentações vigentes e com o modelo de tratamento da organização.

Os testes devem cobrir sites, apps, plataformas de consentimento/escolha, tags de publicidade, SDKs, fluxos server-side, resolução de identidade, partes downstream e comportamento após opt-out.

Capítulo 15 — PI sensível, menores e controles especiais de escolha

Quando aplicável, implemente o direito de limitar determinados usos/divulgações de informações pessoais sensíveis e os avisos ou mecanismos exigidos. Para menores, implemente processos de opt-in e consentimento sensíveis à idade e consistentes com os requisitos aplicáveis.

Não utilize dark patterns ou designs de interface que prejudiquem materialmente a escolha do consumidor.

Capítulo 16 — Incentivos financeiros e gate fail-closed de direitos

Quando incentivos financeiros ou diferenças de preço/serviço dependerem de informações pessoais, mantenha avisos exigidos, registros de avaliação ou justificativa, processos de opt-in/retirada e consistência com os requisitos jurídicos vigentes.

Não aprove o gate quando os avisos divergirem materialmente da prática, as solicitações não puderem ser cumpridas de ponta a ponta, sinais de preferência de opt-out forem ignorados, controles de PI sensível estiverem ausentes ou as escolhas dos consumidores forem prejudicadas pelo comportamento da interface.

Capítulo 17 — Aplicabilidade e entrada de avaliação de riscos

Identifique atividades de tratamento que acionem os requisitos vigentes de avaliação de riscos da Califórnia e mantenha um processo de entrada que capture finalidade, dados, consumidores, tecnologia, benefícios, impactos negativos, salvaguardas, partes interessadas e responsáveis por decisão.

A conformidade de avaliação de riscos faz parte da linha de base vigente de 2026 quando aplicável. As decisões de triagem devem ser documentadas e revistas após mudanças materiais.

Capítulo 18 — Análise e aprovação de avaliação de riscos

Avalie a relação entre benefícios do tratamento e riscos para consumidores usando a metodologia regulatória vigente. Documente fatos, premissas, impactos negativos, salvaguardas, alternativas, risco residual, revisores, aprovação e acompanhamento exigido.

Modelos e pontuações automatizadas podem apoiar consistência, mas não podem estabelecer suficiência jurídica nem substituir revisão humana responsável.

Capítulo 19 — Prontidão para auditoria de cibersegurança

Determine se requisitos de auditoria de cibersegurança se aplicam e construa arquitetura de evidências antes do prazo aplicável de submissão/certificação. Mantenha governança do escopo de auditoria, inventário de sistemas/dados, evidência do programa de segurança, independência do avaliador, achados, remediação e certificação executiva quando exigida.

As regulamentações estão vigentes em 2026, enquanto as primeiras datas de submissão são escalonadas a partir de 2028. Prontidão não deve ser confundida com alegação de que uma submissão em 2026 já é exigível.

Capítulo 20 — Segurança razoável e evidência de incidentes

Implemente segurança razoável apropriada à natureza das informações pessoais e ao risco organizacional. Conecte controle de acesso, gestão de vulnerabilidades, configuração, criptografia ou salvaguardas equivalentes, monitoramento, resposta a incidentes, resiliência, testes, segurança de fornecedores e remediação a evidências.

Quando o direito privado de ação legal puder se aplicar a incidentes de segurança que atendam aos critérios relevantes, preserve fatos e evidências para revisão jurídica competente sem emitir conclusões automatizadas de responsabilidade.

Capítulo 21 — Inventário ADMT e triagem de decisões significativas

Inventarie tecnologias de tomada automatizada de decisões e identifique finalidades, entradas, saídas, consumidores afetados, envolvimento humano, decisões influenciadas, fornecedores, modelos, fontes de dados, riscos e histórico de mudanças.

Determine se um uso se enquadra nas regras ADMT aplicáveis e nos conceitos de decisão significativa por meio de revisão controlada jurídica/de privacidade. Não presuma que todo algoritmo está coberto nem que todo design com pessoa no circuito está isento.

Capítulo 22 — Aviso prévio ao uso de ADMT, acesso e prontidão de opt-out

Quando aplicável, projete avisos prévios ao uso, informações de acesso ao consumidor, processos de opt-out, tratamento de exceções, aplicação downstream, testes, evidências e gestão de mudanças para ADMT.

A conformidade de ADMT começa em 1º de janeiro de 2027 quando aplicável. O Manual 12 deve ensinar prontidão em 2026 sem representar obrigações futuras como se já fossem exigíveis.

Capítulo 23 — Prestadores de serviços, contratados e terceiros

Governe relações downstream por meio de classificação de papéis, restrições contratuais exigidas, limitações de finalidade/uso, segurança, assistência a direitos do consumidor, propagação de eliminação/correção, direitos de auditoria/testes quando aplicável, controles de venda/compartilhamento, subcontratação, retenção e revisão de mudanças materiais.

Rótulos contratuais devem corresponder ao comportamento operacional real e ao uso de dados.

Capítulo 24 — Gate fail-closed de risco/segurança/ADMT

Não aprove o gate quando avaliações de risco exigidas estiverem ausentes ou sem suporte, a aplicabilidade de auditorias de cibersegurança for ignorada, fragilidades materiais de segurança não tiverem responsável, usos de ADMT não estiverem inventariados ou datas futuras de conformidade forem representadas de forma imprecisa.

A automação pode apoiar inventário, coleta de evidência, testes e prazos; não pode tomar conclusões jurídicas finais sobre suficiência de avaliação de riscos, aplicabilidade de auditoria, cobertura ADMT ou responsabilidade.

Capítulo 25 — Operações de retenção, eliminação e qualidade de dados

Defina retenção por finalidade, categoria, sistema, parte downstream, necessidade jurídica/de negócio e requisito de evidência. Implemente processos de eliminação, arquivamento, exceções/legal hold, backup, dados derivados e validação alinhados às finalidades divulgadas e aos requisitos de minimização.

Os períodos de retenção devem ser explicáveis e revisados periodicamente, em vez de adotar armazenamento indefinido por padrão.

Capítulo 26 — Ecossistemas de publicidade, medição e identidade

Mapeie pixels, SDKs, cookies, eventos server-side, clean rooms, serviços de resolução de identidade, provedores de medição, parceiros de dados e plataformas de publicidade para categorias de dados, finalidades, análise de venda/compartilhamento, contratos, comportamento de opt-out, tratamento de PI sensível e retenção.

Testes técnicos devem verificar o comportamento real de rede e server-side após as escolhas do consumidor.

Capítulo 27 — Distinções de data brokers e DROP

Determine separadamente se requisitos de registro de data brokers ou obrigações do Delete Act/DROP se aplicam. Mantenha processos de registro, divulgação, solicitações de eliminação, correspondência de identidade, eliminação downstream, exceções, evidências e prontidão para auditoria quando relevante.

Não aplique deveres de data broker/DROP mecanicamente a todas as empresas e não os omita quando existir uma operação coberta de data broker.

Capítulo 28 — Registros e evidência

Mantenha evidências de decisão e operação para aplicabilidade, avisos, solicitações de consumidores, verificação, sinais de preferência de opt-out, PI sensível, contratos, avaliações de risco, prontidão para auditoria de cibersegurança, ADMT, retenção, data brokers, incidentes, treinamento, testes e ações corretivas.

A evidência deve ser atribuível, atual, delimitada ao tratamento real e protegida contra alteração inadequada.

Capítulo 29 — Treinamento e competência operacional

Forneça treinamento baseado em funções para privacidade, jurídico, marketing, publicidade, produto, engenharia, segurança, compras, suporte ao cliente, RH, analytics/dados, auditoria e liderança. O treinamento deve incluir cenários realistas específicos da Califórnia e erros comuns de implementação.

Acompanhe conclusão, defeitos recorrentes, lições de solicitações de consumidores e incidentes e mudanças de comportamento quando mensuráveis.

Capítulo 30 — Prontidão para fiscalização e resposta regulatória

Mantenha um pacote organizado de evidências e um processo de escalonamento para consultas, auditorias, investigações, reclamações ou ações de fiscalização da CPPA ou do Procurador-Geral. Preserve fatos relevantes, decisões, comunicações, evidências técnicas, contratos, avaliações de risco, registros de segurança e remediação.

Respostas regulatórias exigem revisão coordenada e competente jurídico/de privacidade e representações exatas da prática atual e histórica.

Capítulo 31 — Asseguração, métricas e ação corretiva

Avalie se os controles de privacidade da Califórnia estão adequadamente desenhados, implementados, operando, evidenciados e melhorados. Medidas úteis incluem pontualidade/qualidade de solicitações, falhas de sinais de opt-out, avisos desatualizados, fluxos de dados não revisados, ações de avaliação de risco não resolvidas, falhas de retenção, defeitos de terceiros, lacunas no inventário ADMT e problemas recorrentes de segurança.

QA do repositório e testes internos não certificam conformidade nem preveem resultados regulatórios.

Capítulo 32 — Limite de liberação do manual e melhoria contínua

O Manual 12 só é encerrado quando a verificação de fontes, o mestre inglês controlado de 32 capítulos, a revisão editorial de privacidade/jurídica/técnica, a localização es-419 e pt-BR com revisão semântica humana, a revisão de gráficos/acessibilidade, QA de publicação DOCX/PDF, revisão de segurança do repositório/workflows, manifesto/checksums/proveniência e reconciliação de escopo alterado no head exato estiverem concluídos para o mesmo candidato exato. A autorização final de liberação aplica-se conforme o procedimento permanente do repositório quando todos os gates substantivos anteriores estiverem verdes.

A conclusão estabelece uma linha de base revisada de implementação e treinamento. Ela não fornece aconselhamento jurídico específico para uma organização, não garante conformidade com CCPA, não determina responsabilidade nem substitui profissionais competentes jurídico/de privacidade ou reguladores.